Corso di Cybersecurity – Epicode

Report dell'Esercitazione

Rilevamento di attacchi brute-force SSH con Splunk

Detection, triage e distinzione tra attività malevola esterna e accessi legittimi

A cura di:

Nicola Madonna

Epicode

3 novembre 2026

Indice

1 Riassunto 2
2 Obiettivi 2
3 Configurazione del Laboratorio 3
3.1 Ambiente e dati 3
3.2 Metodo di analisi 3
4 Analisi dei Dati Raccolti 4
4.1 Panoramica 4
4.2 Rilevamento e triage del brute-force 4
4.3 Evidenza: un attacco a dizionario 5
4.4 Verifica dell'esito: l'attacco ha avuto successo? 5
4.5 Regola di detection (alert) 6
4.6 Mappatura MITRE ATT&CK 7
4.7 Contromisure 7
5 Conclusioni 8

1 Riassunto

In questo laboratorio Splunk è stato usato come SIEM per monitorare i log di autenticazione SSH di un server (file `secure.log`) e rilevare attività di tipo brute-force. L'analisi ha individuato una vasta campagna di *password spray*: 185 indirizzi IP esterni distinti hanno generato oltre 66.000 tentativi di accesso falliti, provando in modo sistematico più di 140 nomi utente diversi, quasi tutti account di default e di servizio (`root`, `admin`, `oracle`, `postgres`, `nagios` e simili), un comportamento tipico di uno strumento automatizzato.

Il punto centrale del lavoro non è stato rilevare l'attacco, ma **valutarne l'esito e separarlo dall'attività legittima**. Incrociando tentativi falliti e accessi riusciti è emerso che nessuno degli IP attaccanti è mai riuscito ad autenticarsi: tutti i 3.198 accessi andati a buon fine provengono da tre soli indirizzi interni (rete `10.0.0.0/8`), ciascuno associato a un unico utente legittimo. La campagna, per quanto intensa e continua, è stata quindi interamente respinta.

Il laboratorio si chiude con una dashboard di monitoraggio che riassume la situazione in un'unica vista, con la definizione di una regola di detection (alert) e con la mappatura dell'attività osservata sul framework MITRE ATT&CK.

2 Obiettivi

- Utilizzare Splunk come SIEM per interrogare i log di autenticazione SSH.
- Rilevare i tentativi di accesso falliti e classificarli, distinguendo il brute-force dal rumore di fondo.
- Verificare se gli attacchi hanno avuto successo, separando l'attività malevola esterna dagli accessi legittimi interni.
- Costruire una dashboard di monitoraggio e definire una regola di detection riutilizzabile.
- Inquadrare l'attività osservata nel framework MITRE ATT&CK e proporre contromisure.

3 Configurazione del Laboratorio

3.1 Ambiente e dati

L'analisi è stata svolta su Splunk Enterprise (licenza Free) installato sull'host `Epicode Server`. Il dataset analizzato è un log di autenticazione in stile `/var/log/secure` di un sistema Linux, indicizzato nell'indice `main` con sourcetype `www1/secure`, per circa 80.000 eventi complessivi tra accessi riusciti e falliti. È lo stesso tipo di dato che un SOC riceve quotidianamente dai server esposti: ogni riga registra un tentativo di login SSH, con esito, nome utente e indirizzo IP di origine.

3.2 Metodo di analisi

Poiché il sourcetype non applica un'estrazione automatica dei campi, i valori utili (esito, utente, IP sorgente) sono stati estratti a runtime con il comando `rex` tramite espressioni regolari, e poi aggregati con `stats`. Questo approccio rende le ricerche indipendenti dalla configurazione dell'input e riproducibili su qualsiasi istanza.

4 Analisi dei Dati Raccolti

4.1 Panoramica

La dashboard costruita (Fig. 1) sintetizza i numeri chiave: 66.506 login falliti, 3.198 riusciti, 185 IP sorgente coinvolti nei fallimenti e, soprattutto, **zero accessi riusciti provenienti da IP esterni**. L'andamento nel tempo mostra picchi giornalieri regolari, tipici di uno strumento automatico che ripete la propria sessione a intervalli fissi.

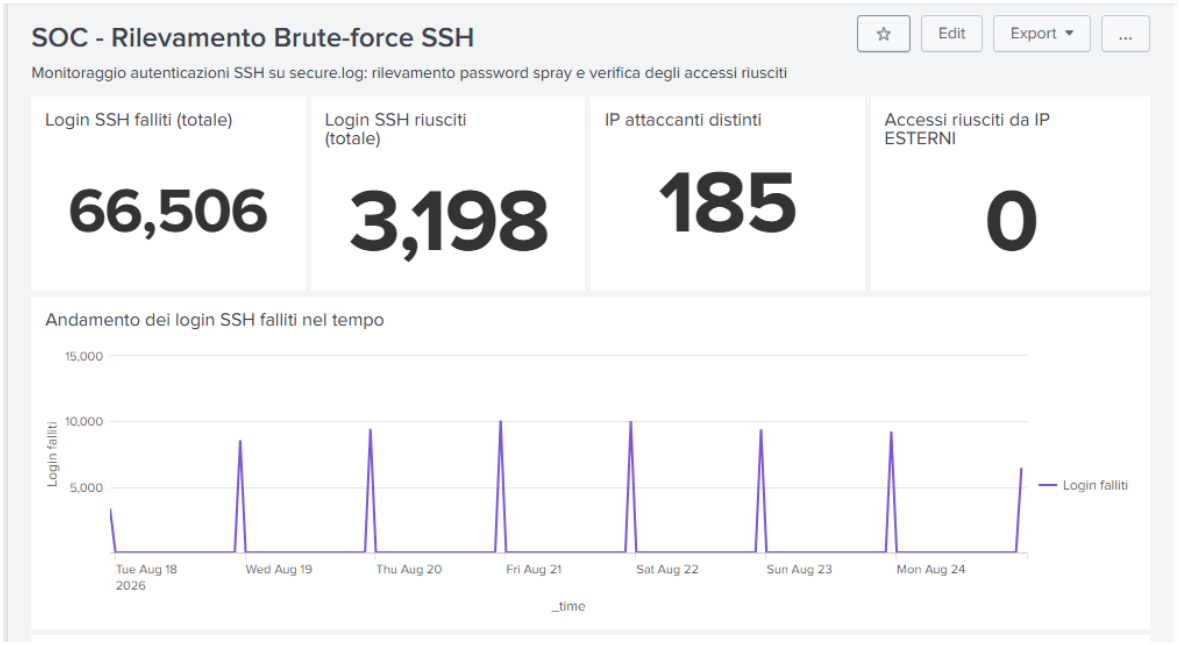


Figura 1: Indicatori principali e andamento temporale dei login SSH falliti.

4.2 Rilevamento e triage del brute-force

La prima ricerca isola i login falliti, estrae utente e IP e conta i tentativi per ciascun IP, aggiungendo una classificazione automatica:

```
index=main sourcetype="www1/secure" "Failed password"
| rex "Failed password for (?:invalid user )?(?<user>\S+) from (?<src_ip>\d
   {1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3})"
| stats count AS tentativi_falliti, dc(user) AS utenti_distinti by src_ip
| eval classificazione=case(utenti_distinti>=5,"Password spray",
   tentativi_falliti>=20,"Brute-force mirato", 1==1,"Rumore")
| sort - tentativi_falliti | head 15
```

La ricerca iniziale restituiva 182 indirizzi IP: troppi per un'ispezione manuale. Il valore del lavoro di un analista sta proprio qui, nel *triage*: la clausola `eval` etichetta ogni IP in base al comportamento (molti utenti diversi → *password spray*; molti tentativi → *brute-force mirato*; il resto → rumore), e `head 15` riduce l'insieme ai 15 IP più aggressivi, quelli che giustificano l'apertura di un'indagine (Fig. 2). Tutti e 15 ricadono nella categoria *password spray*.

Events Patterns **Statistics (15)** Visualization

Show: 20 Per Page ▾ Format ▾ Preview: On

src_ip	tentativi_falliti	utenti_distinti	classificazione
87.194.216.51	1896	140	Password spray (molti utenti)
211.166.11.101	1486	135	Password spray (molti utenti)
128.241.220.82	1244	129	Password spray (molti utenti)
109.169.32.135	1030	122	Password spray (molti utenti)
194.215.205.19	1028	128	Password spray (molti utenti)
216.221.226.11	866	124	Password spray (molti utenti)
188.138.40.166	594	106	Password spray (molti utenti)
65.19.167.94	572	103	Password spray (molti utenti)
107.3.146.207	564	108	Password spray (molti utenti)
95.130.170.231	558	106	Password spray (molti utenti)
223.205.219.67	548	112	Password spray (molti utenti)
27.1.11.11	546	98	Password spray (molti utenti)
27.35.11.11	540	103	Password spray (molti utenti)
59.162.167.100	534	96	Password spray (molti utenti)
91.210.104.143	506	99	Password spray (molti utenti)

Figura 2: Top 15 degli IP sorgente per tentativi falliti, con classificazione automatica.

4.3 Evidenza: un attacco a dizionario

Isolando l'IP più attivo, `87.194.216.51`, emerge la natura dell'attacco: 1.896 tentativi falliti contro 140 nomi utente diversi (Fig. 3). La lista non è casuale: `root`, `admin`, `administrator`, `apache`, `backup`, `couchdb`, `daemon`, `db2`, `oracle`, `postgres` e decine di altri account di default e di servizio. È un attacco a dizionario, che prova sistematicamente username noti nel tentativo di individuare una password debole.

src_ip	tentativi_falliti	utenti_distinti	utenti
87.194.216.51	1896	140	abc adm admin administrator agushto alex amanda amavis angel apache appserver art backup bashful ben beyonce bfsuser bin brian britany carrie cher couchdb customer cyrus daemon dasusr1 db db2 db2fenc1 db2inst1 db4 dba

Figura 3: Dettaglio dell'IP `87.194.216.51`: 140 nomi utente provati, tutti account di default o di servizio.

4.4 Verifica dell'esito: l'attacco ha avuto successo?

È la domanda centrale nell'analisi di un SOC. Una seconda ricerca seleziona i soli IP che hanno registrato *sia* un elevato numero di tentativi falliti *sia* almeno un accesso riuscito:

```
index=main sourcetype="www1/secure" ("Failed password" OR "Accepted password")
| rex "(?<esito>Failed|Accepted) password for (?:invalid user )?(?<user>\S+)
   from (?<src_ip>\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3})"
| stats count(eval(esito=="Failed")) AS falliti, count(eval(esito=="Accepted"))
    AS riusciti, values(eval(if(esito=="Accepted",user,null()))) AS
   utenti_compromessi by src_ip
| where falliti>=20 AND riusciti>=1
```

Il risultato è **vuoto**: nessuno degli IP responsabili dell'attività di brute-force è poi riuscito ad autenticarsi. Per capire allora da dove arrivino i 3.198 accessi riusciti, una terza ricerca li elenca per IP sorgente (Fig. 4): provengono da soli tre indirizzi, tutti nella rete interna `10.0.0.0/8`, ciascuno legato a un unico utente (`djohnson`, `nsharpe`, `myuan`). È il profilo tipico di tre postazioni aziendali con un dipendente ciascuna.

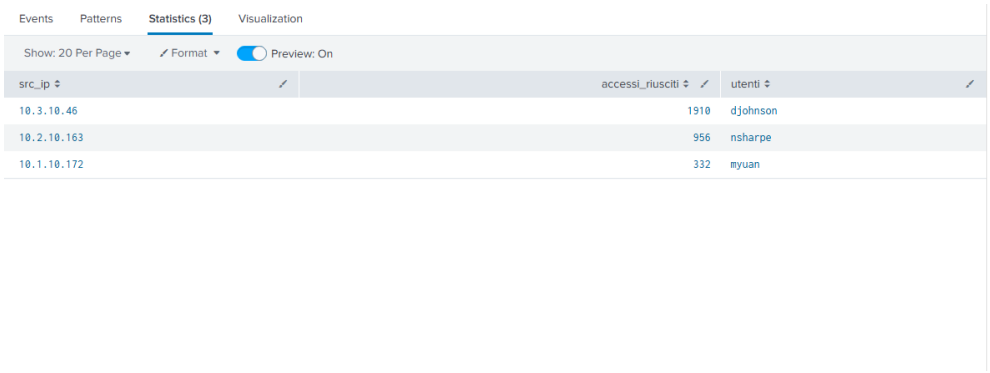


Figura 4: Accessi SSH riusciti: tre soli IP interni, ognuno con un utente legittimo.

Si ottiene così la distinzione che è il cuore del lavoro di un analista: da un lato un'intensa attività malevola proveniente da decine di IP pubblici, tutta respinta; dall'altro un numero ristretto di accessi legittimi dalla rete interna. Il campo *Accessi riusciti da IP esterni*, pari a **zero**, riassume l'esito difensivo dell'intero periodo.

4.5 Regola di detection (alert)

In un SOC questa logica non viene eseguita manualmente, ma automatizzata come ricerca schedulata che genera un alert. La query dell'alert, da eseguire su una finestra mobile (ad esempio l'ultima ora), è:

```
index=main sourcetype="www1/secure" "Failed password" earliest=-1h
| rex "from (?<src_ip>\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3})"
| stats count AS tentativi by src_ip
| where tentativi >= 20
```

Si configurerebbe come *scheduled search* ogni 5–15 minuti, con azione di notifica (e-mail al team o ticket) quando un IP supera la soglia. In questo laboratorio la licenza Free di Splunk non consente le ricerche schedulate, quindi la regola è documentata ma non attivata; in un ambiente con licenza Enterprise verrebbe salvata come alert operativo.

4.6 Mappatura MITRE ATT&CK

L'attività osservata si colloca con precisione nel framework MITRE ATT&CK (Tabella 1).

Tabella 1: Mappatura dell'attività osservata su MITRE ATT&CK.

Tecnica	**ID**	**Riscontro nei dati**
Brute Force	T1110	Oltre 66.000 tentativi di autenticazione falliti verso il servizio SSH.
Password Spraying	T1110.003	Ogni IP prova molti username diversi con pochi tentativi ciascuno, per eludere i blocchi account.
Valid Accounts	T1078	Obiettivo finale dell'attacco: ottenere credenziali valide. Nel periodo analizzato non è stato raggiunto.

4.7 Contromisure

Per ridurre la superficie d'attacco e il rischio che una campagna simile vada a segno:

- **Non esporre SSH su Internet:** limitare l'accesso tramite VPN o firewall, consentendo la porta 22 solo da indirizzi autorizzati.
- **Disabilitare l'autenticazione a password:** usare le chiavi SSH e disattivare il login diretto di `root`.
- **Bloccare gli IP aggressivi:** strumenti come `fail2ban` bannano automaticamente gli indirizzi che superano una soglia di tentativi falliti.
- **Policy di lockout e password robuste:** per neutralizzare gli attacchi a dizionario sugli account deboli.
- **Monitorare in continuo:** mantenere attiva nel SIEM la regola di detection descritta, così che un eventuale accesso riuscito dopo molti fallimenti generi subito un alert.

5 Conclusioni

Questo laboratorio ha mostrato il flusso di lavoro tipico di un analista SOC su un SIEM: dall'acquisizione dei log di autenticazione alla scrittura delle ricerche di detection, dal triage di centinaia di sorgenti alla verifica dell'esito reale dell'attacco. Il risultato più significativo non è stato rilevare il brute-force, cosa che qualsiasi conteggio evidenzia, ma **interpretarlo**: classificare le sorgenti, riconoscere l'attacco a dizionario e, soprattutto, distinguere l'attività malevola esterna (interamente respinta) dagli accessi legittimi interni.

È la stessa capacità di giudizio che separa un allarme reale da un falso positivo, ed è il valore che un analista aggiunge agli strumenti automatici. Il passo successivo naturale, in un ambiente di produzione, è trasformare queste ricerche in alert schedulati e in una dashboard sempre attiva, in modo che il monitoraggio non dipenda più dall'esecuzione manuale delle query.